Risk ID	Asset	Threat	Vulnerability	Risk Statement	Likelihood	Impact
R-001	Employee laptops	Malware	Weak endpoint security	Malware could infect employee laptops because of weak endpoint security, potentially exposing company information or disrupting operations.	4 - Likely	4 - Major
R-002	Microsoft 365	Account compromise	Lack of MFA	Account compromise could happen if MFA is not used. A cybercriminal could gain unauthorized access to Microsoft 365 and expose company information.	3 - Possible	5 - Severe
R-003	Customer database	Unauthorized access	Excessive user permissions	Unauthorized access could occur because of excessive user permissions, potentially exposing customer information in the customer database.	3 - Possible	4 - Major
R-004	Company data accessible to third-party inventory software vendor	Cybercriminal compromises vendor systems or account	BrightPath does not regularly review third-party vendor cybersecurity controls	Because BrightPath does not regularly review its third-party vendor's cybersecurity controls, a cybercriminal could compromise the vendor's systems or account and gain unauthorized access to BrightPath's data, potentially exposing company information.	3 - Possible	4 - Major
R-005	Critical Business Data and Backup Systems	Ransomware (system failure is also in scenario)	Backup restoration is not regularly tested to confirm company data can be recovered when needed	Because backup restoration is not regularly tested, ransomware could make BrightPath's business data unavailable, potentially delaying recovery and disrupting business operations.	3	4

Inherent Risk Score	Existing Controls	Control Gap	Risk Owner	Risk Treatment
16	Antivirus software and endpoint security	Existing endpoint security is not strong enough to consistently detect and block malware.	IT Security Manager	Mitigate
15	Password requirements; account lockout; Microsoft 365 login monitoring	MFA is not consistently enforced for all Microsoft 365 accounts.	IAM Manager	Mitigate
12	Individual employee accounts; password requirements; database access restricted to authorized employees; access activity logged	Some employees have more access to customer information than necessary for their job responsibilities.	IAM Manager	Mitigate
12	Vendor security controls have not been regularly reviewed, and the effectiveness of the vendor's existing security measures has not been verified. Specific vendor controls have not been confirmed.	BrightPath does not regularly assess or verify the vendor's cybersecurity controls.	Vendor Risk Manager	Mitigate
12	BrightPath maintains backups, but backup restoration has not been regularly tested. Other backup security protections have not been verified.	BrightPath does not regularly test backup restoration to verify that critical business data can be recovered successfully when needed.	IT Infrastructure Manager	Mitigate

Recommended Controls	Residual Likelihood	Residual Impact	Residual Risk Score
Strengthen endpoint security, improve antivirus protection, and improve incident response.	3 - Possible	4 - Major	12
Enforce MFA for all Microsoft 365 accounts.	2 - Unlikely	5 - Severe	10
Apply least privilege so employees only have access needed for their jobs; conduct regular access reviews; remove unnecessary database permissions promptly.	2 - Unlikely	4 - Major	8
Conduct regular vendor security reviews; limit vendor access to only the data and systems needed; require MFA for vendor accounts where supported.	2 - Unlikely	4 - Major	8
1. Regularly test backup restoration to confirm critical business data can be recovered successfully. 2. Document restoration test results and issues identified. 3. Remediate backup and recovery problems found during testing.	3	4	12

Remaining Risk / Further Action	Risk Status	NIST Function	NIST Category
Continue monitoring the risk, strengthen endpoint security, and have the SOC prioritize malware-related activity.	In Progress	Protect (PR)	PR.PS - Platform Security
Continue monitoring Microsoft 365 accounts for suspicious login activity and periodically review account access and MFA enrollment.	In Progress	Protect (PR)	PR.AA - Identity Management, Authentication, and Access Control
BrightPath should regularly review database access to make sure employees only have permissions needed for their jobs. Unnecessary permissions should be removed promptly, and database access logs should be monitored for suspicious activity.	In Progress	Protect (PR)	PR.AA - Identity Management, Authentication, and Access Control
Conduct regular vendor security reviews, verify that required security controls remain in place, and review vendor access periodically. Address identified weaknesses promptly.	In Progress	Govern (GV)	GV.SC - Cybersecurity Supply Chain Risk Management
Continue checking backups regularly and testing restoration to confirm critical business data can be recovered when needed. Fix problems found during testing promptly and continue monitoring backup reliability because ransomware and system failures may still occur.	In Progress	Recover (RC)	RC.RP — Incident Recovery Plan Execution

NIST Subcategory
PR.PS-05 - Installation and execution of unauthorized software are prevented
PR.AA-03 - Users, services, and hardware are authenticated
PR.AA-05 - Access permissions, entitlements, and authorizations are defined in a policy, managed, enforced, and reviewed, and incorporate least privilege and separation of duties
GV.SC-07 - Supplier and third-party risks are understood, recorded, prioritized, assessed, responded to, and monitored throughout the relationship
RC.RP-03 — The integrity of backups and other restoration assets is verified before using them for restoration.